

Security Scan Report

Target: <https://www.spit.ac.in/>

Scan Date: August 26, 2026 at 14:09 UTC

Scan ID: aa63e733-fa40-4f6d-abbd-fadb894b0aaa

0 CRITICAL

0 HIGH

2 MEDIUM

3 LOW

Executive Summary

Security scan of 'https://www.spit.ac.in/' identified 5 raw findings, reduced to 5 unique issues after deduplication. 2 MEDIUM-priority issue(s) should be addressed in the current development sprint. 3 LOW-priority issue(s) have been logged for backlog tracking.

Scan Statistics

Metric	Value
Total Raw Findings	5
After Deduplication	5
Critical Findings	0
High Findings	0
Medium Findings	2
Low Findings	3
Scan Duration	56.5s

Detailed Findings

[MEDIUM] #1: Information Disclosure in robots.txt:0

Risk Score	0.4220
Affected Location	https://www.spit.ac.in/robots.txt:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in robots.txt. robots.

Code or HTTP Excerpt

```
1 | GET /robots.txt → HTTP 200
2 | Content-Length: 157 bytes
3 | Preview: User-agent: *
4 | Disallow: /wp-admin/
5 | Allow: /wp-admin/admin-ajax.php
6 |
7 | Sitemap: https://www.spit.ac.in/sitemap.xml
8 | Sitemap: https://www.spit.ac.in/sitema
```

Business Impact

The disclosed the admin panel helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Review robots.txt for sensitive path disclosure. While robots.txt is public, listing hidden paths like /admin or /backup reveals targets to attackers. Use authentication instead of obscurity.

[MEDIUM] #2: Information Disclosure in sitemap.xml:0

Risk Score	0.3492
Affected Location	https://www.spit.ac.in/sitemap.xml:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in sitemap.xml. sitemap.

Code or HTTP Excerpt

```
1 | GET /sitemap.xml → HTTP 200
2 | Content-Length: 1087 bytes
3 | Preview: <?xml version='1.0' encoding='UTF-8'?><?xml-stylesheet type='text/xsl' href='https://www.sp
```

Business Impact

The disclosed internal network services helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

[LOW] #3: Open Redirect in nirf:0

Risk Score	0.3492
Affected Location	https://www.spit.ac.in/nirf:0
Vulnerability Type	OPEN_REDIRECT
CWE ID	CWE-601
Detected By	url-scanner

Explanation

Open redirect allows attackers to redirect users from your trusted domain to a malicious site via a URL parameter. Found in nirf. Open redirect detected via parameter 'url'.

Code or HTTP Excerpt

```
1 | Request: GET https://www.spit.ac.in/nirf?url=https%3A%2F%2Fevil.example.com
2 | Response: HTTP 301
3 | Location: https://www.spit.ac.in/nirf/?url=https%3A%2F%2Fevil.example.com
```

Business Impact

Attackers could send users convincing phishing links via your application's redirect endpoint that appear to originate from your trusted domain.

Fix Recommendation

Best Fix: Validate redirect URLs against a whitelist of allowed domains. Use relative paths for internal redirects. Reject external URLs.

[LOW] #4: Missing Security Header in :0

Risk Score	0.3136
Affected Location	https://www.spit.ac.in/:0
Vulnerability Type	MISSING_SECURITY_HEADER
CWE ID	CWE-693
Detected By	url-scanner

Explanation

The server response is missing recommended HTTP security headers that instruct browsers to enable built-in protections. Found in . Missing Content-Security-Policy (CSP) header.

Code or HTTP Excerpt

```
1 | Response headers: Content-Security-Policy = (not set)
```

Business Impact

Without this header, users' browsers is more vulnerable to XSS, clickjacking, or MIME-type confusion attacks.

Fix Recommendation

Best Fix: Add a Content-Security-Policy header to restrict script sources: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'.

[LOW] #5: Information Disclosure in :0

Risk Score	0.2496
Affected Location	https://www.spit.ac.in/:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in . Missing Referrer-Policy header.

Code or HTTP Excerpt

```
1 | Response headers: Referrer-Policy = (not set)
```

Business Impact

The disclosed server configuration details helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Best Fix: Remove or restrict access to the exposed sensitive information. Suppress version headers, block sensitive file access, and disable debug output in production.

Appendix

Deduplication Statistics

Total raw findings: 5 | After deduplication: 5 | Reduction: 0%

Scan Metadata

Scan ID	aa63e733-fa40-4f6d-abbd-fadb894b0aaa
Target	https://www.spit.ac.in/
Timestamp	2026-08-26T14:09:54.599379+00:00
Duration	56.5s
Scanners Used	url-scanner
Scanner Versions	url-scanner=builtin-1.0

Raw Findings Data (JSON)

```
[
  {
    "id": "e71265c6-9d28-4e1a-a450-0b37da0fddeb",
    "title": "Information Disclosure in robots.txt:0",
    "file": "https://www.spit.ac.in/robots.txt",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "robots.txt may reveal hidden paths and sensitive directories.",
    "rule_id": "sensitive-path-robots.txt",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /robots.txt \u2192 HTTP 200\nContent-Length: 157 bytes\nPreview: User-agent: *\nDi",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.422,
    "risk_category": "MEDIUM",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
    "fix_suggestion": "Review robots.txt for sensitive path disclosure. While robots.txt is public, listing",
    "business_impact": "The disclosed the admin panel helps attackers identify attack vectors, reducing the",
    "raw": {
      "url": "https://www.spit.ac.in/robots.txt",
      "status": 200,
      "path": "/robots.txt"
    }
  },
  {
    "id": "86aed9e0-9f19-4493-bd18-802a1df94f9f",
    "title": "Information Disclosure in sitemap.xml:0",
    "file": "https://www.spit.ac.in/sitemap.xml",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "INFORMATION_DISCLOSURE",
```

```

    "description": "sitemap.xml may reveal internal URL structure.",
    "rule_id": "sensitive-path-sitemap.xml",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /sitemap.xml \u2192 HTTP 200\nContent-Length: 1087 bytes\nPreview: <?xml version='1
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.3492,
    "risk_category": "MEDIUM",
    "category_source": "consistency_cache",
    "category_reason": "locked to historical category MEDIUM",
    "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
    "fix_suggestion": "Remove or restrict access to the exposed sensitive information. Suppress version head
    "business_impact": "The disclosed internal network services helps attackers identify attack vectors, re
    "raw": {
        "url": "https://www.spit.ac.in/sitemap.xml",
        "status": 200,
        "path": "/sitemap.xml"
    }
},
{
    "id": "ae04f68c-d586-4e68-a91b-66f1458fee6e",
    "title": "Open Redirect in nirf:0",
    "file": "https://www.spit.ac.in/nirf",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "OPEN_REDIRECT",
    "description": "Open redirect detected via parameter 'url'. The application redirects to attacker-control
    "rule_id": "open-redirect",
    "confidence": 0.85,
    "cwe_id": "CWE-601",
    "cvss_score": null,
    "code_snippet": "Request: GET https://www.spit.ac.in/nirf?url=https%3A%2F%2Fevil.example.com\nResponse:
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.3492,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "Open redirect allows attackers to redirect users from your trusted domain to a malic
    "fix_suggestion": "Validate redirect URLs against a whitelist of allowed domains. Use relative paths for
    "business_impact": "Attackers could send users convincing phishing links via your application's redirect
    "raw": {
        "url": "https://www.spit.ac.in/nirf",
        "param": "url",
        "redirect_to": "https://www.spit.ac.in/nirf/?url=https%3A%2F%2Fevil.example.com"
    }
},
{
    "id": "b5c94987-430c-44db-81fa-977a358dc1a8",
    "title": "Missing Security Header in :0",
    "file": "https://www.spit.ac.in/",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "MISSING_SECURITY_HEADER",
    "description": "Missing Content-Security-Policy (CSP) header. Without CSP, the site is more vulnerable t
    "rule_id": "header-missing-content-security-policy",
    "confidence": 0.9,
    "cwe_id": "CWE-693",
    "cvss_score": null,
    "code_snippet": "Response headers: Content-Security-Policy = (not set)",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.3136,
    "risk_category": "LOW",

```

```

    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server response is missing recommended HTTP security headers that instruct brow
    "fix_suggestion": "Add a Content-Security-Policy header to restrict script sources: default-src 'self';
    "business_impact": "Without this header, users' browsers is more vulnerable to XSS, clickjacking, or MI
    "raw": {
      "url": "https://www.spit.ac.in/",
      "header": "Content-Security-Policy",
      "check": "missing_header"
    }
  },
  {
    "id": "abebfd17-bc7e-49c0-a167-8dfbe1ffc742",
    "title": "Information Disclosure in :0",
    "file": "https://www.spit.ac.in/",
    "line_start": 0,
    "line_end": null,
    "severity": "LOW",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "Missing Referrer-Policy header. Sensitive information in URLs may be leaked to third-par
    "rule_id": "header-missing-referrer-policy",
    "confidence": 0.8,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "Response headers: Referrer-Policy = (not set)",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.2496,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted
    "fix_suggestion": "Remove or restrict access to the exposed sensitive information. Suppress version hea
    "business_impact": "The disclosed server configuration details helps attackers identify attack vectors,
    "raw": {
      "url": "https://www.spit.ac.in/",
      "header": "Referrer-Policy",
      "check": "missing_header"
    }
  }
]

```